

Security Assessment Report

Generated: 2026-05-05 11:23

Report ID: 69a635d9

Executive Security Report

Executive Summary

Total vulnerabilities: 4

Highrisk issues: 3 critical codequality findings in server.py that increase the chance of logic errors, missed edge cases, and insecure maintenance changes; this can raise operational and security exposure over time.

Overall risk level: High

Technical Details

Finding 1 Excessive cognitive complexity in server.py

Severity: Critical

AI Explanation: One function is too complex, which makes it harder to review, test, and safely change. In securitysensitive code, this increases the risk of hidden logic flaws.

Fix Suggestion: Break the function into smaller helper functions and simplify nested conditionals/loops.

Finding 2 Excessive cognitive complexity in another server.py function

Severity: Critical

AI Explanation: A second function also exceeds acceptable complexity limits. This suggests the codebase has maintainability hotspots that could conceal bugs.

Fix Suggestion: Refactor repeated logic into reusable helpers and reduce branching depth.

Finding 3 Excessive cognitive complexity in a third server.py function

Severity: Critical

AI Explanation: A third function is similarly overcomplex, which raises the chance of regression when changes are made.

Fix Suggestion: Rework the function into clearer, smaller units with explicit responsibility boundaries.

Finding 4 Commentedout code present in server.py

Severity: Medium

AI Explanation: Leftover commented code adds noise and can confuse future maintainers about what is active versus obsolete.

Fix Suggestion: Remove dead/commented code and rely on version control for recovery.

Tool outcomes (Bandit, Sonar, Safety, ZAP): Succeeded or Failed with reasons.

Bandit: Succeeded — scanned /workspace/uploads/39e48c32d11b and found no Python security issues.

Sonar: Succeeded — reported 5 issues, including 3 critical cognitivecomplexity findings and 2 minor codesmell findings.

Safety: Failed — no requirements.txt found in project, so dependency scanning could not run.

ZAP: Not run — no URL target was provided, so dynamic web scanning was not applicable.

Tool Failures

Safety scan could not execute because the project does not contain a requirements.txt file.

ZAP was not performed because the input was a local code path, not an HTTP/HTTPS URL.